

UD3: Seguridad Física y Lógica de Sistemas

Bloque 6 | 20 horas

Marco normativo: RD 311/2022 ENS Anexo II · ISO/IEC 27001:2022

Complementos: RGPD art. 32 · IEC 62443 (entornos industriales) · CCN-STIC

FÍSICA

LÓGICA

ACCESO

AUDITORÍA

Contenidos de la Unidad

01

Seguridad física e industrial

Perímetros, control de acceso físico, climatización, alimentación eléctrica

02

Seguridad lógica de sistemas

Sistemas de ficheros, ACLs, directorio de usuarios, autenticación

03

Control de acceso lógico avanzado

Contraseñas, MFA, biometría, SSO, PAM

04

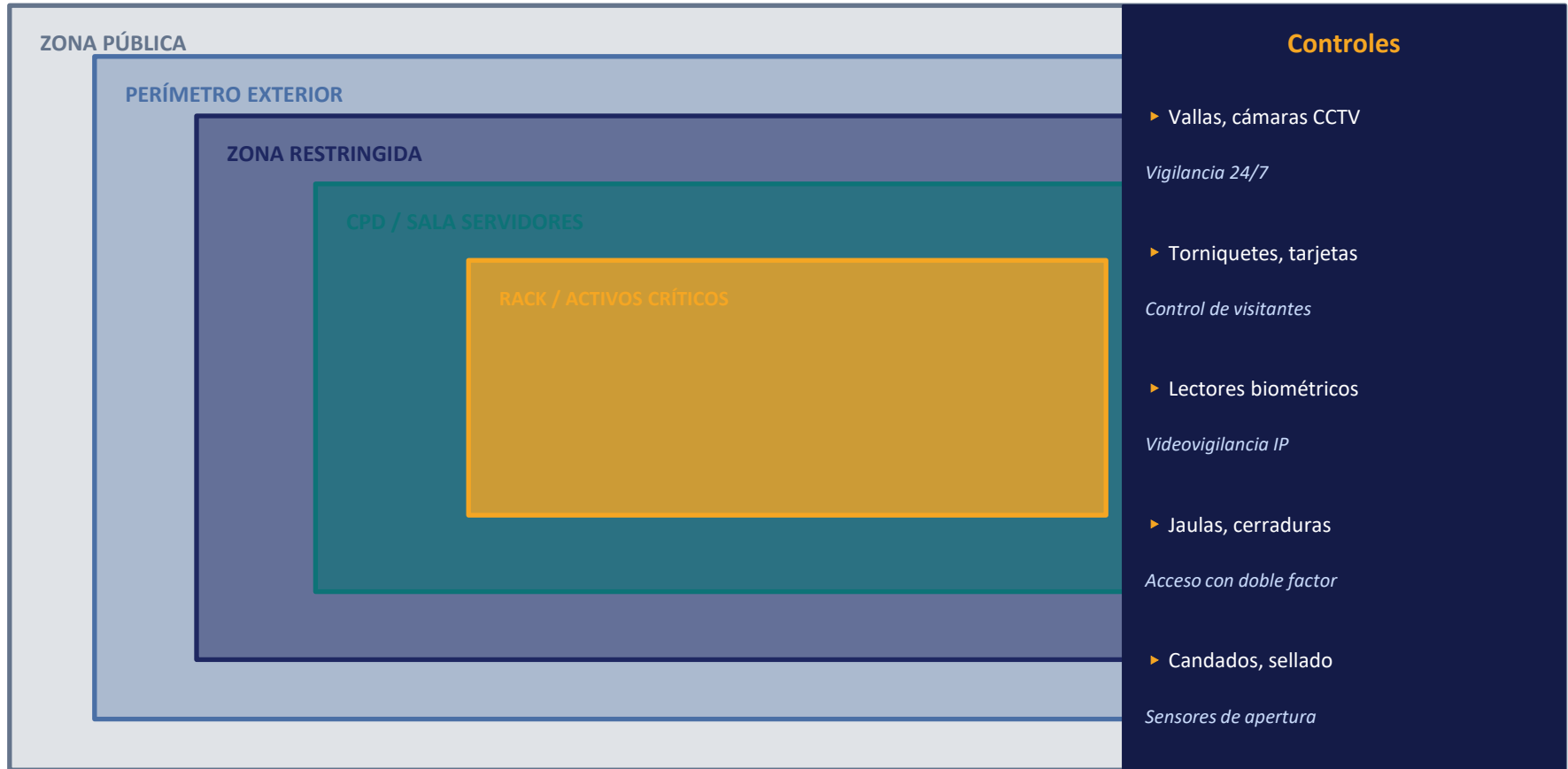
Auditoría y monitorización

Registros de auditoría, SIEM, normativa de control de accesos

01

Seguridad Física e Industrial

Bloque 6 · Perímetros, CPD, climatización, suministro eléctrico



Tarjetas y Credenciales

- Tarjeta magnética (baja seguridad)
- Tarjeta RFID / Smart Card
- Tarjeta NFC (móvil)
- Credencial con PIN combinado

Biometría

- Huella dactilar (FAR/FRR)
- Reconocimiento facial
- Iris / retina
- Geometría de la mano
- Voz (speaker recognition)

Sistemas Integrados

- Control de rondas (guardas)
- Sistemas PACS (Physical Access Control)
- Videovigilancia IP + analítica IA
- Interlocking / esclusa
- Torniquete / mantramp

Métricas de fiabilidad en sistemas biométricos

Métrica	Definición	Impacto en seguridad
FAR (False Acceptance Rate)	% de impostores aceptados erróneamente	Alto FAR → riesgo de acceso no autorizado
FRR (False Rejection Rate)	% de usuarios legítimos rechazados	Alto FRR → impacto en usabilidad
EER (Equal Error Rate)	Punto donde FAR = FRR: balance óptimo	Menor EER = sistema más preciso

Ubicación y construcción

- ▶ Planta sin ventanas al exterior (preferible sótano o interior)
- ▶ Muros y techos resistentes al fuego (EI 120 mín.)
- ▶ Ausencia de tuberías de agua sobre equipos
- ▶ Distancia a zonas de riesgo (inundación, vuelo, etc.)

Control ambiental

- ▶ Temperatura: 18-27 °C (ASHRAE A1/A2)
- ▶ Humedad relativa: 40-60 % sin condensación
- ▶ Sistema HVAC redundante (N+1 mínimo)
- ▶ Monitorización continua T/H con alertas

Protección contra incendios

- ▶ Detección: detectores de humo muy temprano (VESDA)
- ▶ Extinción: gas inerte (FM-200, Novec 1230, CO2)
- ▶ Compartimentación: sectorización contra incendios
- ▶ Inhibición: sin rociadores de agua en sala servidores

- ▶ SAI/UPS: autonomía mínima 15-30 min para shutdown
- ▶ Grupo electrógeno: arranque automático <10 s
- ▶ Acometidas eléctricas redundantes (A+B)
- ▶ PDU monitorizadas con protección contra sobretensión

02

Seguridad Lógica de Sistemas

Bloque 6 · Sistemas de ficheros, ACLs, directorio de usuarios

Sistemas de ficheros habituales

NTFS (Windows)

ACLs granulares, EFS (cifrado), cuotas, auditoría nativa, VSS (shadow copies).

ext4 (Linux)

Journaling, permisos POSIX (rwx), ACLs POSIX con setfacl/getfacl, SELinux/AppArmor.

APFS (macOS)

Cifrado nativo AES, snapshots, clones, ACLs POSIX extendidas.

ZFS

Copy-on-Write, checksums de integridad, RAID-Z, cifrado, snapshots atómicos.

Btrfs (Linux)

Snapshots, compresión, RAID software, checksums, subvolúmenes.

Listas de Control de Acceso (ACLs)

Modelo DAC (Discretionary Access Control)

El propietario del recurso asigna permisos. Base del modelo POSIX (rwxrwxrwx) y ACLs NTFS.

Modelo MAC (Mandatory Access Control)

El sistema impone las reglas (SELinux, AppArmor, Smack). El usuario no puede modificar etiquetas de seguridad.

Modelo RBAC (Role-Based Access Control)

Permisos asignados a roles; usuarios se asignan a roles. Estándar en AD/LDAP, aplicaciones empresariales.

Modelo ABAC (Attribute-Based Access Control)

Decisiones basadas en atributos del sujeto, recurso y entorno. Más granular y flexible que RBAC.

Lab: setfacl / getfacl en Linux · icacs en Windows · GPO en Active Directory

Estructura Active Directory (AD DS)

Bosque (Forest)

Límite de seguridad máximo. Contiene uno o más dominios con relaciones de confianza.

Dominio

Unidad administrativa. Tiene su propia base de datos (NTDS.dit) y política de contraseñas.

Unidad Organizativa (OU)

Contenedor para objetos (usuarios, equipos, grupos). Destino de GPOs.

Objeto de Directiva de Grupo (GPO)

Configuración de seguridad aplicada a OUs: contraseñas, bloqueo, software, auditoría.

Cuentas de servicio (GMSA)

Cuentas administradas por el dominio: rotación automática de contraseña, sin login interactivo.

GPO: Política de contraseñas

Longitud mínima

12 caracteres (recomendado: 16+)

Complejidad

May + min + número + símbolo

Historial

Recordar últimas 24 contraseñas

Vigencia máxima

Sin expiración (NIST SP 800-63B)

Vigencia mínima

1 día (evitar bypass historial)

Política de bloqueo de cuenta

Umbral de bloqueo: 5 intentos fallidos

Duración del bloqueo: 30 min (o reset por admin)

Contador de intentos: Reset cada 15 min

03

Autenticación Avanzada

Bloque 6 · Factores, MFA, biometría, PAM

Factor 1 SABES	Factor 2 TIENES	Factor 3 ERES
• Contraseña / PIN • Frase de paso • Pregunta secreta • Patrón de desbloqueo	• OTP por SMS/email • TOTP (Google Auth, FIDO2) • Token hardware (RSA SecurID) • Smart card / certificado digital	• Huella dactilar • Reconocimiento facial • Iris / retina • Voz / escritura
<i>Débil sola — sujeta a phishing, fuerza bruta, reutilización</i>	<i>Robusto si el canal secundario es seguro</i>	<i>FAR/FRR: equilibrio entre seguridad y usabilidad</i>

MFA = combinación de 2 o más factores distintos

Estándares: FIDO2/WebAuthn · TOTP (RFC 6238) · HOTP (RFC 4226) · SAML 2.0 · OAuth 2.0 + OIDC

PAM (Privileged Access Management): gestión de cuentas privilegiadas con grabación de sesiones, rotación automática de contraseñas y control de comandos. Ejemplos: CyberArk, BeyondTrust, HashiCorp Vault.

04

Auditoría y Monitorización

Bloque 6 · Logs del SO, SIEM, normativa de accesos

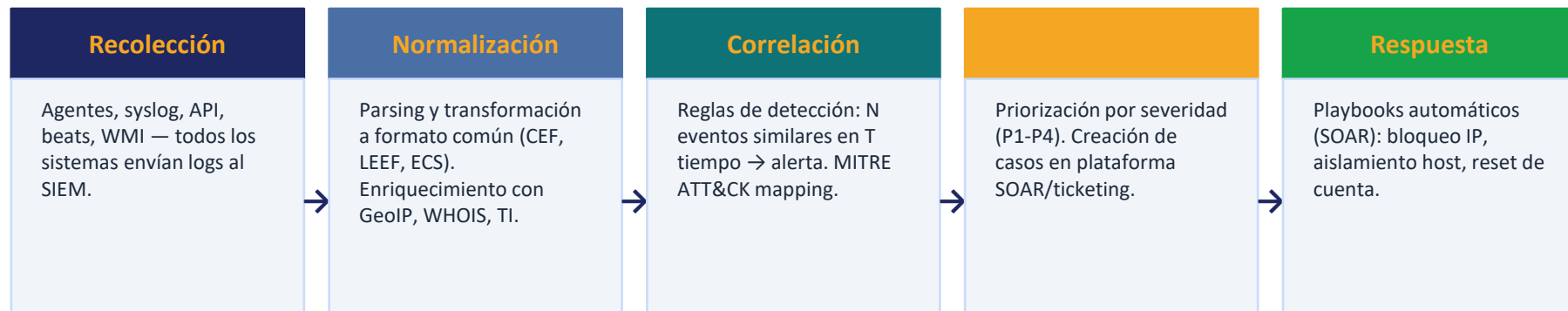
Los registros de auditoría (logs) son la base de la trazabilidad y el no repudio. El ENS (Anexo II, familia [op]) y el RGPD (art. 5.f) exigen su existencia, integridad y disponibilidad.

Windows — Event Viewer / Wevtutil

4624	Inicio de sesión satisfactorio
4625	Inicio de sesión fallido
4648	Inicio de sesión con credenciales explícitas
4720	Cuenta de usuario creada
4740	Cuenta de usuario bloqueada
4776	Validación de credenciales en DC
7045	Nuevo servicio instalado en el sistema

Linux — journald / syslog / auditd

/var/log/auth.log	Autenticación SSH, sudo, PAM
/var/log/syslog	Eventos generales del sistema
/var/log/audit/audit.log	Reglas auditd: syscalls, ficheros
auditctl -w	Monitorizar fichero o directorio
auresearch	Búsqueda en logs de auditoría
aureport	Informes resumidos de auditoría
journalctl -u sshd	Logs filtrados por unidad systemd



Herramientas del laboratorio SOC

Security Onion 2.4 SIEM/NSM	Elastic Stack + Suricata + Zeek + Strelka. Correlación, hunt y detección en un solo despliegue.	Wazuh 4.x EDR/HIDS	Agente en endpoints: FIM, detección de vulnerabilidades, conformidad (PCI-DSS, HIPAA, RGPD).
TheHive SOAR/Casos	Gestión de incidentes, casos, tareas y observables. Integración con MISP y Cortex para análisis.	OPNsense Firewall/IDS	Suricata IDS/IPS en borde. Logs exportados al SIEM. Reglas personalizadas por tráfico de lab.

La normativa de control de accesos es el documento interno que establece las reglas de uso aceptable, la gestión del ciclo de vida de cuentas y los procedimientos de acceso privilegiado.

Ciclo de vida de cuentas

- ▶ Alta: solicitud formal, aprobación del responsable, mínimo privilegio.
- ▶ Modificación: cambio de rol/departamento → revisión de permisos.
- ▶ Revisión periódica: mínimo anual (auditoría de cuentas y privilegios).
- ▶ Baja: deshabilitación inmediata al cesar la relación laboral.

Gestión de acceso privilegiado

- ▶ Cuentas administrativas separadas de las de usuario normal.
- ▶ Uso de PAM: grabación de sesión, aprobación de acceso just-in-time.
- ▶ Principio de mínimo privilegio y separación de funciones (SoD).
- ▶ Rotación de contraseñas de cuentas de servicio (GMSA/vaults).

Uso aceptable y concienciación

- ▶ Política de escritorio limpio y pantalla bloqueada (NIST).
- ▶ Prohibición de compartir credenciales o dispositivos de acceso.
- ▶ Formación anual obligatoria en seguridad y privacidad.
- ▶ Canal de reporte de incidentes y sospechas de compromiso.

Resumen UD3

1

La seguridad física se organiza en perímetros concéntricos: público → restringido → CPD → rack, con controles específicos en cada capa

2

El CPD requiere control ambiental (18-27 °C, 40-60 % HR), protección contra incendios con gas inerte y suministro eléctrico redundante (SAI + grupo)

3

Las ACLs implementan DAC, MAC, RBAC o ABAC según el modelo de control; en Linux con setfacl, en Windows con NTFS/GPO

4

Las políticas de contraseñas siguen NIST SP 800-63B: longitud ≥ 12 , sin expiración periódica, MFA obligatorio para acceso privilegiado

5

Los logs de auditoría (Event IDs en Windows, auditd en Linux) son la base de la trazabilidad y el análisis forense

6

El SIEM (Security Onion en el lab) correlaciona eventos de múltiples fuentes; Wazuh aporta EDR/HIDS en endpoints